

## MAISON DE FLOF

## BÁO CÁO DOANH NGHIỆP

*Quy trình xây dựng, quản trị và vận hành dự án Maison de FLOF*

**Loại tài liệu**

Báo cáo quản trị vòng đời dự án website

**Đối tượng hệ thống**

Website thương mại điện tử sơn và tư vấn màu Maison de FLOF

**Cơ sở phân tích**

Mã nguồn, Prisma schema, migration, test, CI, audit và roadmap trong repository

**Ngày lập báo cáo**

11/06/2026

Tài liệu chuyển hóa hiện trạng kỹ thuật của Maison de FLOF thành quy trình doanh nghiệp có mục tiêu, vai trò, quality gate, kiểm soát rủi ro, kế hoạch phát hành và vận hành. Báo cáo dùng làm hồ sơ quản trị, nghiệm thu và định hướng production readiness.

*Phiên bản 1.0 | Tài liệu nội bộ phục vụ đề án và quản trị dự án*

## Mục lục nội dung

### Tóm tắt điều hành

Hiện trạng, kết luận và quyết định ưu tiên

### 1. Project charter và business case

Mục tiêu, phạm vi, stakeholder, KPI

### 2. Quy trình delivery end-to-end

Khởi tạo đến vận hành

### 3. Quản trị yêu cầu, kiến trúc và dữ liệu

Artifacts, design review và governance

### 4. Quản trị chất lượng, bảo mật và phát hành

Test, CI/CD, security và release gates

### 5. Vận hành, rủi ro và roadmap

SLO, incident, risk register và lộ trình

### Phụ lục

RACI, Definition of Done, checklist release

## Tóm tắt điều hành

Maison de FLOF đã có phạm vi chức năng rộng và nền tảng kỹ thuật tốt hơn một prototype thông thường. Hệ thống có storefront, cổng quản trị, schema 29 model, migration, CI, transaction, idempotency, payment record, inventory ledger, RBAC và audit log. Các khoảng trống quyết định mức sẵn sàng production hiện nằm ở integration/E2E, đối soát thanh toán thật, deploy/staging, monitoring, backup và runbook.

### Khuyến nghị điều hành

Tạm ưu tiên hardening và vận hành thay vì mở rộng tính năng. Release production chỉ nên được phê duyệt khi checkout/payment/order transition có bằng chứng E2E, migration và rollback được thử, monitoring hoạt động, và trách nhiệm vận hành đã được giao rõ.

| Chỉ số hiện trạng | Giá trị            | Ý nghĩa quản trị                                   |
|-------------------|--------------------|----------------------------------------------------|
| Trang giao diện   | 31                 | Phạm vi trải nghiệm đã tương đối rộng              |
| API routes        | 40                 | Cần contract/authorization test có hệ thống        |
| Model / enum      | 29 / 11            | Miền dữ liệu đủ lớn để cần governance              |
| Migration         | 6                  | Đã có nền tảng quản lý thay đổi DB                 |
| Test tự động      | 11                 | Tăng từ 6 nhưng chưa đủ integration/E2E            |
| Dependency audit  | 2 moderate còn lại | Theo dõi bản vá tương thích; không force downgrade |

**Bảng 1. Chỉ số hiện trạng và thông tin liên quan**

## 1. Project charter và business case

### 1.1 Business case

Dự án tạo một kênh bán hàng và tư vấn màu trực tuyến giúp khách hàng đưa ra quyết định mua sơn tốt hơn, đồng thời chuẩn hóa vận hành đơn hàng, payment, tồn kho, nội dung và chăm sóc khách hàng. Giá trị doanh nghiệp đến từ tăng chuyển đổi, giảm thao tác thủ công, cải thiện khả năng truy vết và tạo nền tảng dữ liệu cho quản trị.

### 1.2 Mục tiêu

| Mục tiêu          | Kết quả mong đợi                            | KPI đề xuất                                     |
|-------------------|---------------------------------------------|-------------------------------------------------|
| Doanh thu số      | Khách có thể khám phá đến checkout trọn vẹn | Conversion, cart abandonment, order success     |
| Hiệu quả vận hành | Đơn/payment/kho được xử lý có lịch sử       | Thời gian xử lý, sai lệch đối soát              |
| Quản trị rủi ro   | Thao tác nhạy cảm được phân quyền và audit  | Unauthorized attempts, audit coverage           |
| Chất lượng        | Mỗi release có bằng chứng kiểm chứng        | Pass rate, escaped defects, change failure rate |
| Độ tin cậy        | Phát hiện và khôi phục sự cố nhanh          | Availability, MTTD, MTTR                        |

Bảng 2. Mục tiêu và thông tin liên quan

### 1.3 Phạm vi và nguyên tắc ưu tiên

- Phạm vi cốt lõi: storefront, commerce, account, support, content và admin.
- Bắt buộc trước production: tính toàn vẹn giao dịch, payment control, authorization, test, migration, monitoring và runbook.
- Có thể sau bản đầu: automation nâng cao, analytics chuyên sâu, ERP/CRM integration và mobile native.
- Không mở rộng tính năng nếu quality gate của luồng commerce trọng yếu chưa đạt.

### 1.4 Stakeholder và RACI

| Hoạt động             | Business owner | PM/BA | Tech lead/Dev | QA | Operations |
|-----------------------|----------------|-------|---------------|----|------------|
| Phê duyệt phạm vi/KPI | A              | R     | C             | C  | C          |

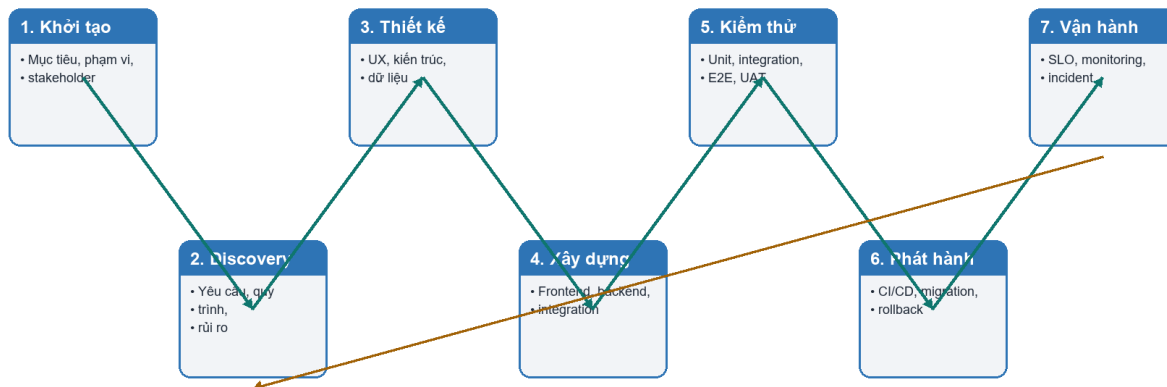
| Hoạt động                      | Business owner | PM/BA | Tech lead/Dev | QA  | Operations |
|--------------------------------|----------------|-------|---------------|-----|------------|
| Yêu cầu và acceptance criteria | A              | R     | C             | C   | I          |
| Kiến trúc và dữ liệu           | I              | C     | A/R           | C   | C          |
| Kiểm thử và UAT                | C              | C     | R             | A/R | C          |
| Release và migration           | I              | C     | R             | C   | A/R        |
| Incident và hậu kiểm           | I              | C     | R             | C   | A/R        |

Bảng 3. Hoạt động và thông tin liên quan

Quy ước: A = Accountable, R = Responsible, C = Consulted, I = Informed.

## 2. Quy trình delivery end-to-end

### Quy trình phát triển và vận hành dự án



Vòng phản hồi từ vận hành quay lại discovery và backlog

Hình 1. Quy trình phát triển và vận hành dự án

### 2.1 Khởi tạo

Xác định business case, sponsor, phạm vi, KPI, ngân sách, giả định và ràng buộc. Đầu ra bắt buộc gồm project charter, stakeholder map, high-level roadmap và cơ chế ra quyết định.

## 2.2 Discovery và phân tích yêu cầu

Khảo sát hành vi khách hàng, quy trình nhân viên, dữ liệu hiện hữu và rủi ro vận hành. Mỗi requirement phải có chủ sở hữu, acceptance criteria, độ ưu tiên, dependency và traceability đến thiết kế/test.

## 2.3 Thiết kế

Thiết kế bao gồm user flow, wireframe/UI, kiến trúc logic, ERD, API contract, security model và kế hoạch migration. Design review tập trung vào invariant tiền/kho/trạng thái, quyền hạn, khả năng vận hành và chi phí thay đổi.

## 2.4 Lập kế hoạch và xây dựng

Backlog được chia theo vertical slice có thể kiểm chứng. Mỗi thay đổi đi qua code review, lint, typecheck, test và build. Các feature flag hoặc chiến lược rollout được dùng cho thay đổi có rủi ro cao.

## 2.5 Kiểm thử, phát hành và vận hành

Bộ kiểm thử bao gồm unit, policy, integration, E2E, UAT và non-functional theo mức rủi ro. Release cần kế hoạch migration/rollback, observability, runbook và người trực vận hành. Sau phát hành phải review KPI, lỗi và bài học để cập nhật backlog.

| Giai đoạn | Artifact bắt buộc                         | Gate phê duyệt                       |
|-----------|-------------------------------------------|--------------------------------------|
| Khởi tạo  | Charter, scope, KPI, stakeholder          | Sponsor phê duyệt giá trị và phạm vi |
| Discovery | Requirement, process map, risk log        | Backlog ready                        |
| Thiết kế  | Architecture, ERD, API, UX, threat model  | Design ready                         |
| Xây dựng  | Code, migration, test, documentation      | Code ready                           |
| Phát hành | UAT, release plan, rollback, runbook      | Release ready                        |
| Vận hành  | Dashboard, alert, incident record, review | Operate ready                        |

Bảng 4. Giai đoạn và thông tin liên quan

## 3. Quản trị yêu cầu, kiến trúc và dữ liệu

### 3.1 Quản trị yêu cầu

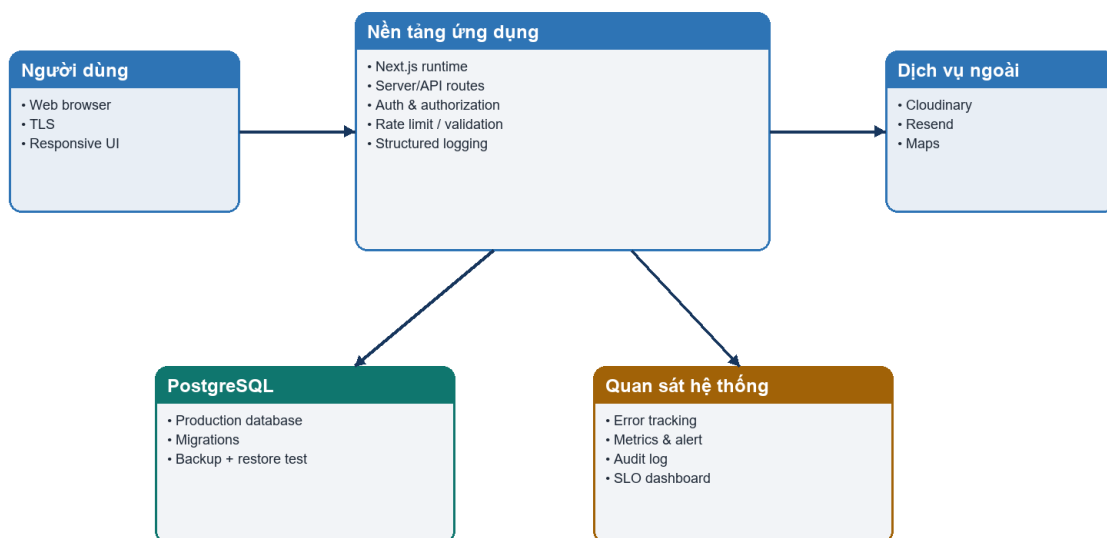
| Trường requirement | Nội dung tối thiểu                                  |
|--------------------|-----------------------------------------------------|
| Mã và mô tả        | Một mục tiêu nghiệp vụ rõ, không trộn nhiều hành vi |

| Trường requirement   | Nội dung tối thiểu                            |
|----------------------|-----------------------------------------------|
| Actor và trigger     | Ai khởi tạo và sự kiện nào bắt đầu            |
| Luồng chính/ngoại lệ | Happy path, validation, retry, timeout và lỗi |
| Acceptance criteria  | Điều kiện có thể kiểm thử và đo lường         |
| Dữ liệu/quyền        | Dữ liệu đọc/ghi, ownership và permission      |
| Bằng chứng           | Liên kết thiết kế, code, test và release      |

Bảng 5. Trường requirement và thông tin liên quan

## 3.2 Kiến trúc hiện tại và mục tiêu

### Kiến trúc triển khai mục tiêu



Hình 2. Kiến trúc triển khai mục tiêu

Kiến trúc hiện tại là Next.js full-stack với PostgreSQL/Prisma và dịch vụ ngoài. Để vận hành doanh nghiệp, cần bổ sung lớp quan sát hệ thống, môi trường tách biệt, backup/restore, secret governance, rate limit dùng chung và quy trình deploy có rollback.

## 3.3 Governance dữ liệu

| Dữ liệu | Owner | Kiểm soát bắt buộc | Retention/đánh giá |
|---------|-------|--------------------|--------------------|
|---------|-------|--------------------|--------------------|

| Dữ liệu            | Owner               | Kiểm soát bắt buộc                              | Retention/đánh giá               |
|--------------------|---------------------|-------------------------------------------------|----------------------------------|
| Tài khoản và hồ sơ | Product/Operations  | Least privilege, ownership, bảo vệ PII          | Rà soát truy cập định kỳ         |
| Đơn hàng/payment   | Finance/Operations  | Transaction, idempotency, audit, reconciliation | Theo chính sách tài chính        |
| Tồn kho            | Operations          | Ledger, reference, không sửa trực tiếp          | Đối chiếu định kỳ                |
| Audit log          | Security/Operations | Immutable, truy cập giới hạn                    | Theo nhu cầu điều tra/compliance |
| Media/nội dung     | Marketing           | Ownership, approval, xóa có audit               | Lifecycle policy                 |

Bảng 6. Dữ liệu và thông tin liên quan

### 3.4 Kiểm soát thương mại trọng yếu

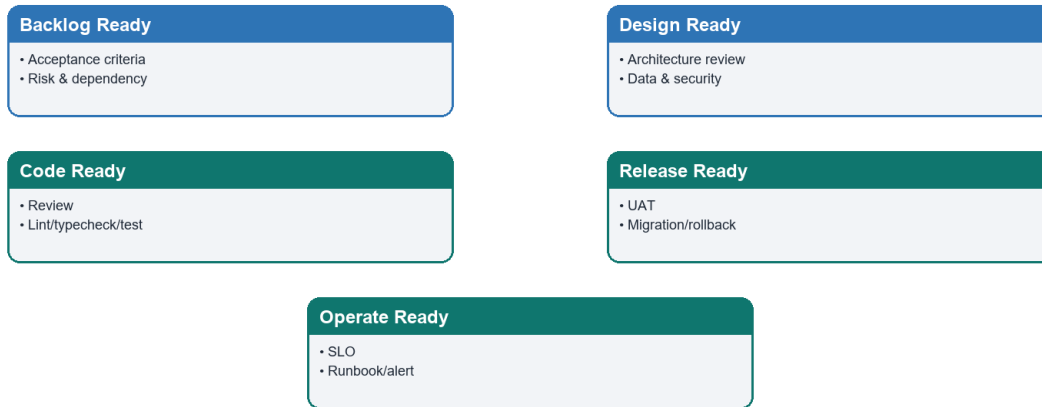
- Server là nguồn tính giá, giảm giá và tổng tiền; không tin dữ liệu giá từ client.
- Checkout sử dụng Idempotency-Key để retry không tạo đơn trùng.
- Order transition dùng conditional update trong transaction để tránh race condition.
- Payment có trạng thái và lịch sử; đối soát/hoàn tiền thủ công có audit.
- Inventory dùng ledger và tham chiếu nghiệp vụ; không cho chỉnh stock trực tiếp.



## 4. Quản trị chất lượng, bảo mật và phát hành

### 4.1 Quality gates

#### Quality gates và quản trị thay đổi



Mỗi gate có chủ sở hữu, bằng chứng kiểm chứng và tiêu chí không được bỏ qua.

Hình 3. Quality gates và quản trị thay đổi

| Gate          | Tiêu chí không được thiếu                       | Bằng chứng                |
|---------------|-------------------------------------------------|---------------------------|
| Backlog Ready | Acceptance criteria, priority, dependency, risk | Requirement record        |
| Design Ready  | Architecture/data/security review               | Decision record, diagrams |
| Code Ready    | Review, lint, typecheck, unit/policy test       | CI pass                   |
| Release Ready | Integration/E2E, UAT, migration và rollback     | Release checklist         |
| Operate Ready | Monitoring, alert, on-call, runbook, backup     | Dashboard và rehearsal    |

Bảng 7. Gate và thông tin liên quan

### 4.2 Chiến lược kiểm thử theo rủi ro

Hiện tại 11 test tự động đã bao phủ một phần logic commerce, security-commerce và paint calculator. Do luồng payment/order/inventory có rủi ro tài chính, doanh nghiệp cần ưu tiên integration test với database thật và E2E cho retry checkout, xác nhận/hoàn tiền, hủy/hoàn tất đơn, permission và audit.

| Ưu tiên | Kịch bản                                                 | Loại test                 |
|---------|----------------------------------------------------------|---------------------------|
| P0      | Retry checkout cùng key chỉ tạo một order                | Integration + concurrency |
| P0      | Hai request hủy/hoàn tất đồng thời không lặp side effect | Integration + concurrency |
| P0      | Staff không truy cập chức năng vượt quyền                | API authorization + E2E   |
| P0      | Payment PAID/REFUNDED có audit và không cập nhật lặp     | Integration               |
| P1      | Catalog, coupon, stock và checkout end-to-end            | E2E                       |
| P1      | Responsive, accessibility và performance                 | Non-functional            |

Bảng 8. Ưu tiên và thông tin liên quan

### 4.3 Bảo mật

| Lĩnh vực        | Hiện trạng                                  | Hành động doanh nghiệp                             |
|-----------------|---------------------------------------------|----------------------------------------------------|
| Identity/access | Auth.js, role guard, permission policy      | Review quyền định kỳ, test deny-by-default         |
| Input/API       | Zod validation ở nhiều route                | Contract test, rate limit shared, abuse monitoring |
| Audit           | AuditLog cho hành động quan trọng           | Retention, alert và truy vấn điều tra              |
| Dependency      | CI audit mức high; còn 2 moderate gián tiếp | Theo dõi bản vá tương thích, exception có hạn dùng |
| Secrets/data    | Env-based configuration                     | Vault/rotation, phân tách môi trường, PII policy   |

Bảng 9. Lĩnh vực và thông tin liên quan

### 4.4 CI/CD và release

CI hiện đã bảo vệ chất lượng code. CD mục tiêu cần tạo preview cho pull request, staging tách biệt, production deploy có approval, migration trước/đồng bộ với ứng dụng, health check, canary hoặc rollback nhanh. Không release khi thiếu bằng chứng cho các gate P0.

## 5. Vận hành, rủi ro và roadmap

### 5.1 Mô hình vận hành

| Năng lực      | Yêu cầu tối thiểu                                                  | Chỉ số                          |
|---------------|--------------------------------------------------------------------|---------------------------------|
| Observability | Structured logs, error tracking, metrics, trace theo request/order | Error rate, latency, saturation |
| Reliability   | Health check, backup/restore, rollback                             | Availability, RPO, RTO          |
| Incident      | On-call, severity, communication, postmortem                       | MTTD, MTTR, recurrence          |
| Commerce ops  | Payment reconciliation, order exception queue                      | Sai lệch, aging, xử lý đúng SLA |
| Security ops  | Audit review, dependency/secret process                            | Findings và thời gian khắc phục |

**Bảng 10. Năng lực và thông tin liên quan**

### 5.2 SLO đề xuất

| Dịch vụ            | SLO ban đầu                                   | Cảnh báo                         |
|--------------------|-----------------------------------------------|----------------------------------|
| Storefront/API     | 99,5% khả dụng theo tháng                     | Burn-rate và lỗi 5xx             |
| Checkout           | 99% request hợp lệ tạo/khôi phục kết quả đúng | Tăng lỗi, timeout, đơn trùng     |
| Payment operations | Đối soát thủ công trong SLA đã cam kết        | Payment PENDING quá hạn          |
| Order operations   | Không lặp side effect do transition đồng thời | Bất thường inventory/audit       |
| Backup             | Khôi phục thử nghiệm theo lịch                | Backup lỗi hoặc restore thất bại |

**Bảng 11. Dịch vụ và thông tin liên quan**

### 5.3 Risk register

| ID | Rủi ro                                           | Mức        | Owner        | Đối sách/tiêu chí đóng                        |
|----|--------------------------------------------------|------------|--------------|-----------------------------------------------|
| R1 | Chưa có đối soát thanh toán tự động              | Cao        | Finance/Ops  | Provider/webhook hoặc SLA đối soát được đo    |
| R2 | Thiếu integration/E2E                            | Cao        | Tech/QA      | Các kịch bản P0 chạy ổn định trong CI/staging |
| R3 | Thiếu monitoring/runbook                         | Cao        | Ops          | Dashboard, alert và incident rehearsal        |
| R4 | Migration chưa áp dụng/kiểm chứng mọi môi trường | Cao        | Tech/Ops     | Staging deploy + rollback rehearsal           |
| R5 | 2 advisory moderate gián tiếp                    | Trung bình | Tech         | Theo dõi patch, exception có ngày hết hạn     |
| R6 | Accessibility/pagination chưa đồng đều           | Trung bình | Product/Tech | Audit và tiêu chí đo đạt                      |

Bảng 12. ID và thông tin liên quan

### 5.4 Roadmap đề xuất

| Giai đoạn                     | Thời lượng tham chiếu | Kết quả                                                                  |
|-------------------------------|-----------------------|--------------------------------------------------------------------------|
| P0 - Commerce hardening       | 2-3 tuần              | Integration/concurrency tests, payment/reconciliation, permission review |
| P1 - Release readiness        | 2-3 tuần              | Staging, deploy/migration/rollback, monitoring, backup, runbook          |
| P2 - UAT và production launch | 1-2 tuần              | UAT, security/accessibility checks, rollout và hypercare                 |
| P3 - Tối ưu vận hành          | Liên tục              | SLO review, automation, analytics và backlog cải tiến                    |

Bảng 13. Giai đoạn và thông tin liên quan

### 5.5 Điều kiện phê duyệt production

- Mọi kịch bản P0 có integration/E2E và chạy đạt trên staging.

2. Migration, rollback và backup/restore đã được diễn tập.
3. Payment reconciliation có owner, SLA, dashboard/queue và audit.
4. Monitoring, alert, incident process và runbook đã hoạt động.
5. Không còn lỗi hổng high/critical; moderate có quyết định chấp nhận rủi ro có hạn dùng.
6. Business owner hoàn tất UAT và ký release checklist.

## Kết luận điều hành

Maison de FLOF đã có nền tảng để trở thành hệ thống doanh nghiệp, nhưng năng lực production không được chứng minh bằng số lượng màn hình. Quyết định phát hành phải dựa trên invariant thương mại, bằng chứng kiểm thử, quyền hạn, khả năng quan sát và năng lực khôi phục. Quy trình trong báo cáo này biến các yêu cầu đó thành gate, trách nhiệm và tiêu chí nghiệm thu cụ thể.

## Phụ lục A. Definition of Done

- Yêu cầu và acceptance criteria đã được cập nhật; phạm vi ngoài yêu cầu được ghi nhận.
- Thiết kế/API/data/security impact đã được review khi cần.
- Code review hoàn tất; không còn lỗi lint/typecheck/build.
- Test phù hợp mức rủi ro đã thêm và chạy đạt.
- Migration tương thích, rollback và dữ liệu mẫu đã được kiểm chứng.
- Authorization, audit và observability được bổ sung cho mutation nhạy cảm.
- Tài liệu vận hành/release note/runbook được cập nhật.

## Phụ lục B. Release checklist

| Hạng mục      | Câu hỏi kiểm tra                               | Chủ sở hữu    |
|---------------|------------------------------------------------|---------------|
| Scope         | Các thay đổi và rủi ro đã được phê duyệt?      | PM/Business   |
| Quality       | CI, integration/E2E và UAT đều đạt?            | Tech/QA       |
| Database      | Migration/rollback/backup đã được thử?         | Tech/Ops      |
| Security      | Quyền, secret, dependency và audit đạt?        | Tech/Security |
| Operations    | Dashboard, alert, on-call và runbook sẵn sàng? | Ops           |
| Communication | Kế hoạch rollout, support và thông báo rõ?     | PM/Ops        |

**Bảng 14. Hạng mục và thông tin liên quan**